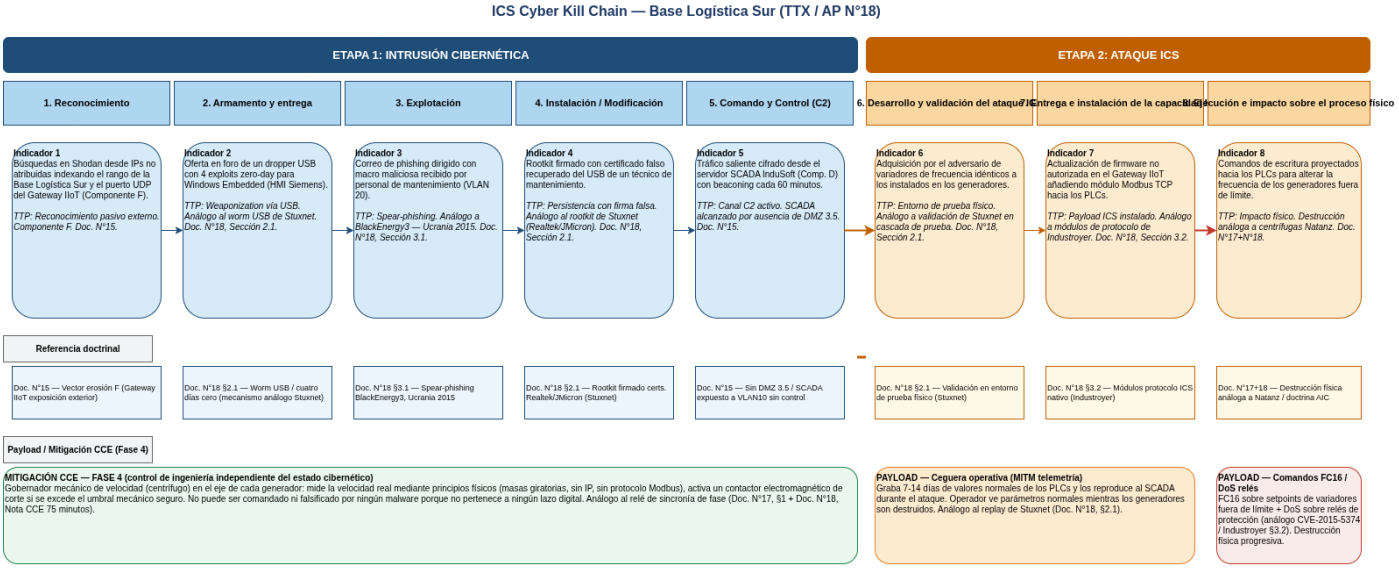
FACULTAD DE DEFENSA NACIONAL — FADENA

Licenciatura en Ciberdefensa | Tecnología Operativa 2026

AP N°18 — Actividad Práctica Integradora (TTX)

Ejercicio de Mesa — ICS Cyber Kill Chain sobre Base Logística Sur



Fase 1 — Clasificación de los 8 indicadores en el ICS Cyber Kill Chain

El diagrama swimlane exportado desde draw.io (AP18_KillChain.xml) presenta la matriz visual completa con los indicadores ubicados en sus columnas correspondientes. La tabla siguiente documenta la justificación técnica de cada asignación.

#	Indicador	Etapa	Fase	Justificación técnica
1	Búsquedas en Shodan indexando el rango de la Base Logística Sur y el puerto UDP del Gateway IIoT (F)	ETAPA 1	Reconocimiento	El adversario construye inteligencia sobre la superficie de ataque observable desde internet. El uso de Shodan para indexar el Gateway F es reconocimiento pasivo: no hay interacción con el sistema, solo observación del vector de erosión IIoT expuesto (Doc. N°15).
2	Oferta en foro de un dropper USB con 4 exploits zero-day para Windows Embedded (HMI Siemens)	ETAPA 1	Armamento y entrega	El arma de entrega está siendo preparada: el dropper USB replica el mecanismo de Stuxnet (worm USB con cuatro días cero diseñado para cruzar el air gap hacia el HMI). Doc. N°18, Sección 2.1.
3	Correo de phishing dirigido con macro maliciosa recibido por personal de mantenimiento (VLAN 20)	ETAPA 1	Explotación	Acceso inicial por el eslabón humano más expuesto — personal de mantenimiento en VLAN 20 (red OT de supervisión). Misma táctica que BlackEnergy3 en Ucrania 2015: spear-phishing con macros maliciosas. Doc. N°18, Sección 3.1.

4	Rootkit firmado con certificado falso recuperado del USB de un técnico de mantenimiento	ETAPA 1	Instalación / Modificación	Persistencia con firma digital falsificada que evade controles de integridad del SO. Réplica directa del rootkit de Stuxnet firmado con certificados robados de Realtek y JMicron. Doc. N°18, Sección 2.1.
5	Tráfico saliente cifrado desde el servidor SCADA InduSoft (D) con beaconing cada 60 minutos	ETAPA 1	Comando y Control (C2)	Beaconing periódico = canal C2 activo. El malware ya alcanzó la VLAN 20 (componente D) y llama al servidor del atacante en intervalos regulares. Posible por ausencia de DMZ 3.5 entre IT y OT. Doc. N°15.
6	Adquisición por el adversario de variadores de frecuencia idénticos a los instalados en los generadores	ETAPA 2	Desarrollo y validación del ataque ICS	El adversario construye un entorno de prueba físico que replica el proceso real — exactamente lo que Stuxnet requirió para validar la lógica de manipulación de variadores antes del despliegue en Natanz. Sin hardware idéntico, el payload de Fase 2 no puede validarse. Doc. N°18, Sección 2.1.
7	Actualización de firmware no autorizada en el Gateway IIoT añadiendo módulo Modbus TCP hacia los PLCs	ETAPA 2	Entrega e instalación de la capacidad ICS	El payload ICS específico es instalado en el sistema objetivo — distinto del malware de intrusión de Etapa 1. El módulo Modbus TCP añadido al firmware del Gateway F puede emitir escrituras FC16 directamente a los PLCs (A): equivalente de los módulos de protocolo ICS de Industroyer. Doc. N°18, Sección 3.2 y Doc. N°16.
8	Comandos de escritura proyectados hacia los PLCs para alterar la frecuencia de los generadores fuera de límite	ETAPA 2	Ejecución e impacto sobre el proceso físico	El efecto físico final: escrituras FC16 sobre setpoints de velocidad de los variadores fuera de los límites mecánicos de diseño — destrucción física análoga a las centrífugas de Natanz. El término 'proyectados' indica reconstrucción prospectiva del TTX. Doc. N°17 y N°18.

Fase 2 — Diseño analítico del TTX

A) Diseño del payload ICS (con mecanismo de ceguera operativa obligatorio)

El payload diseñado para la Etapa 2 consta de tres componentes que operan en conjunto, inspirados en Stuxnet e Industroyer:

Componente 1 — MITM de telemetría (ceguera operativa)

Antes de activar la manipulación de frecuencia, el módulo instalado en el firmware del Gateway F (Indicador 7) graba entre 7 y 14 días de valores normales de proceso leídos desde los registros de entrada de los PLCs — velocidad de rotación, temperatura de bobinado, voltaje de salida — y los reproduce como respuesta a cualquier poll de lectura Modbus proveniente del SCADA InduSoft (D). El operador ve parámetros normales mientras el ataque real está en ejecución: ninguna alarma se activa porque las alarmas están definidas sobre los valores de telemetría leídos por el SCADA, no sobre el estado físico real del generador. Es el mecanismo de replay exacto de Stuxnet (Doc. N°18, Sección 2.1: grabación de 13 días de valores normales hacia WinCC).

Componente 2 — Manipulación de setpoints de variadores

El módulo Modbus TCP emite escrituras FC16 hacia los registros de setpoint de velocidad de los variadores de frecuencia. El ciclo de ataque alterna entre sobrevelocidad (muy por encima del límite de diseño) y subvelocidad (muy por debajo del mínimo) de forma cíclica, con períodos diseñados para maximizar el esfuerzo mecánico sobre bobinados y rodamientos sin activar la protección térmica electrónica — que también está ciega por el Componente 1.

Componente 3 — DoS sobre relés de protección

Simultáneo con el inicio del ciclo de manipulación, el payload envía paquetes especialmente formados al puerto de configuración de los relés de protección de los generadores, análogo al DoS CVE-2015-5374 contra los relés SIPROTEC en Industroyer (Doc. N°18, Sección 3.2). Esto neutraliza la última barrera de protección independiente antes de que pueda detectar la condición de sobrevelocidad y desconectar el generador.

B) Diseño de la mitigación de Fase 4 — CCE (física/mecánica, sin soluciones IT)

La guía establece explícitamente que no se aceptan soluciones informáticas (firewalls, VLANs, MFA). La solución debe operar de forma autónoma aunque todos los sistemas lógicos estén comprometidos.

Mitigación propuesta: Gobernador mecánico de velocidad con trip analógico independiente

Instalado directamente en el eje de cada generador, un gobernador centrífugo mecánico mide la velocidad de rotación real mediante principios puramente físicos (fuerza centrífuga sobre masas giratorias) y activa un contactor electromagnético de corte que desconecta la alimentación del variador de frecuencia cuando la velocidad excede el umbral mecánico seguro. No usa ningún sensor digital, no tiene dirección IP, no procesa ningún protocolo Modbus, y no puede ser comandado remotamente por ningún malware.

Por qué este control es efectivo contra los tres componentes del payload: (1) el MITM de telemetría falsifica los valores que el SCADA lee via Modbus, pero no tiene forma de falsificar la velocidad angular real del eje físico que el gobernador mecánico mide directamente; (2) el ciclo de sobrevelocidad/subvelocidad activa el trip mecánico antes de alcanzar el límite destructivo; (3) el DoS contra los relés de protección electrónicos no tiene efecto sobre un mecanismo basado en masas giratorias y resortes. Es el mismo principio que el relé de sincronía de fase del caso Aurora (Doc. N°17, Sección 1, Nota de Ciberdefensa) y el confirmado empíricamente en Kyiv 2016 con los 75 minutos de restauración manual (Doc. N°18, Nota de Ciberdefensa — 75 minutos).

Fase 3 — Síntesis doctrinal y consulta cruzada

Pregunta de cierre: ¿Qué lección doctrinal unifica los ocho indicadores del TTX?

Los ocho indicadores del TTX, mapeados a las dos etapas del ICS Cyber Kill Chain, demuestran empíricamente la premisa central que atraviesa toda la Unidad 4: un adversario sofisticado no ataca el OT directamente — construye una cadena de cinco pasos en el dominio IT (Etapa 1) para llegar a tres pasos en el dominio OT (Etapa 2), y la frontera entre ambos dominios es el único punto donde una defensa IT tradicional puede interrumpir la cadena antes de que el daño físico sea inevitable.

Vínculo con los documentos de cátedra

- Doc. N°15 (convergencia IT/OT, Sección 1.2): los Indicadores 1–5 solo son posibles porque la arquitectura tiene los cinco vectores de erosión del Modelo Purdue activos — Gateway IIoT expuesto (Ind.1), HMI con TeamViewer alcanzable por USB (Ind.2), personal de VLAN 20 alcanzable por phishing (Ind.3), persistencia vía Historian dual-homed (Ind.4) y SCADA sin DMZ 3.5 que permite beaconing (Ind.5).
- Doc. N°16 (IoT/IIoT, Sección 4): los Indicadores 6 y 7 solo son posibles porque el Gateway IIoT tiene capacidad de actualización de firmware remota sin control de integridad criptográfica — la vulnerabilidad estructural de los dispositivos IIoT con ciclo de vida largo descripta en ese documento.
- Doc. N°17 (doctrina AIC/CCE, Secciones 1.1 y 3): el Indicador 8 es el evento de consecuencia catastrófica que la Fase 1 de CCE habría identificado como inaceptable si se hubiera aplicado el análisis previo al incidente — y la mitigación mecánica de la Fase 2B es exactamente la respuesta de Fase 4 de CCE que elimina la capacidad física de que ese evento ocurra aunque la Etapa 2 completa sea exitosa.
- Doc. N°18 (Stuxnet/Industroyer, Secciones 2.1 y 3.2): la cadena completa de 8 indicadores replica, con componentes concretos de Base Logística Sur, la arquitectura del ataque que Stuxnet ejecutó contra Natanz — incluyendo el mecanismo de ceguera operativa MITM y el DoS sobre la capa de protección de Industroyer.

Conclusión doctrinal del TTX

La defensa efectiva no puede basarse en prevenir el acceso del adversario a la red IT — eso es la Etapa 1, y la historia demuestra que nunca puede garantizarse con certeza absoluta. La defensa debe basarse en garantizar que, aun completando las ocho fases del Kill Chain, el daño físico catastrófico no pueda materializarse porque hay un mecanismo de ingeniería independiente del estado cibernético que lo hace físicamente imposible. Esta es la conclusión que el Doc. N°17 formula como doctrina (Sección 3, metodología CCE Fase 4) y que el Doc. N°18 confirma empíricamente con la evidencia de los 75 minutos de Kyiv 2016.